

Can I Own Your NFTs? Understanding the New Attack Surface to NFTs

Yixiao Gao, Muhammad Saad, Adam Oest, Jean Zhang, Bo Han, and Songqing Chen

The authors provide a detailed analysis of the logical structure of the dominant off-chain NFTs, followed by the attack surface analysis.

ABSTRACT

Recent years have witnessed the increasing popularity and market value of Non-Fungible Tokens (NFTs), along with the burgeoning of blockchains and metaverse. The media hypes often imply that NFTs are as secure as the underlying blockchains. In this work, we take a first look into the building blocks of NFTs (i.e., ownership certificates stored on-chain and the metadata and digital assets stored on-chain or off-chain), focusing on understanding the new attack surface and safety of these digital assets (rather than the traditional attacks on blockchains). For this purpose, we provide a detailed analysis of the logical structure of the dominant off-chain NFTs, followed by the attack surface analysis. Our study indicates that specific new attacks could be easily mounted on them. To validate our findings, we experiment by minting our own NFTs on Ethereum and demonstrate that we can successfully mount the attacks with trivial or even no cost. The cause of these new attacks is rooted in the current design of NFTs where the digital assets are decoupled from the contracts deployed on the blockchains. We discuss some future research to address these vulnerabilities.

INTRODUCTION

Recent years have seen the fast development of blockchain and virtual, augmented, and mixed reality (VR/AR/MR) technologies. Naturally, they meet in the metaverse [1] that integrates various techniques to build virtual worlds, where users can live in the form of avatars as their counterparts in the physical world. In the metaverse, by controlling their avatars, users can work, play, meet with others, and conduct all kinds of activities, such as collaborating with each other, participating in virtual events, making digital goods, and trading virtual objects. Such activities create the virtual economy, which is often connected to the real-world economy via different mechanisms, such as blockchain-based cryptocurrencies (e.g., Bitcoin and Ethereum), making the lines between the virtual and real economy blurred.

The future of the metaverse heavily depends on the success of its virtual economy [2]. Currently, Non-Fungible Tokens (NFTs) [3] dominate the virtual economy in the metaverse. NFTs, inspired by colored coins [4], are the blockchain-managed certificates of ownership of the assets. The assets can be physical assets in the real world, but mainly

digital assets in the metaverse [5]. For an NFT, the ownership certificate is always stored on-chain, but the metadata and the digital asset may be stored on-chain or off-chain. Storing digital assets on-chain is expensive. A recent study [6] shows that the assets of over 90 percent NFTs are stored off-chain. Thus, we mainly focus on off-chain NFTs in the following discussion and note the difference with on-chain NFTs wherever appropriate.

Since NFT certificates are managed on the blockchains, NFT records are considered immutable. As a result, NFTs have gained great popularity among cryptocurrency users. For example, in the metaverse, users can rent houses, purchase lands, raise pets, buy and sell various rare digital assets for profit, and so on. The popularity of NFTs is reflected by the increased trading volume over the years. From 2019 to 2021, the NFT buyers have increased by $\approx 41\times$ to 2,302,000, and the sellers have increased from 25,000 to 1,198,000. The trading volume of NFTs has increased from \$24.5 million to \$17.7 billion.

To conduct NFT transactions, multiple-parties are involved as we shall discuss in the subsequent sections, and they rely on the underlying network communications to create, bid, buy, and sell NFTs. Given the popularity of NFTs, attackers started targeting them by compromising the underlying communication links, as well as the digital assets themselves. According to the research from Comparitech [7], over \$86.72 million of NFTs were stolen in 2022, alone. Some well-known attacks have been aimed at NFT trading or gaming platforms. For instance, OpenSea, one of the most popular NFT trading platforms, suffered from a phishing attack in February 2022 and its users lost $\approx$ \$1.7 million. For Axie Infinity, which is an NFT-based game, the blockchain it resided on was attacked and more than 173,600 ethers were lost. There are other cases where the loss is caused by the development team. For example, due to the defect of the deployed smart contracts, AkuDreams locked up \$33 million in April 2022 [8]. These incidents indicate that the security of NFTs deserves more attention, even though the media hypes often imply that NFTs are secure because they are pegged to the immutable blockchain ledger. Wang et al. presented an overview of NFT [9] and discussed some potential threats. However, a significantly large financial loss brings up some important questions: How secure these

NFTs are? What are the potential vulnerabilities that allow an adversary to mount various attacks? What can be done to enhance the security posture of NFT ownership?

To answer these questions, in this study, we take the first step to investigate several important issues by examining the security of NFTs, focusing on the dominant off-chain NFTs to understand the new attack surface (rather than the traditional attacks to the blockchains). For this purpose, we provide an analysis of the NFT logical structure, followed by the attack surface analysis based on the logical structure. Our study indicates that various new attacks could be mounted on NFTs. Since the new attacks are based on the logical structure of the NFTs, all off-chain NFTs, agnostic of the listing platform or even traded individually, are vulnerable to these attacks. To verify our findings, we experiment by minting our own NFTs on Ethereum without using any platforms and demonstrate that we can successfully mount the attacks with trivial or no cost. The root cause of new attacks is the current design of NFTs where the digital assets are decoupled from the contracts deployed on the blockchains, yet without any protection. We discuss some future research directions to address these vulnerabilities.

BACKGROUND

The large volume of markets leads to the rise of a few popular NFT trading platforms, such as OpenSea [5], LooksRare [10], Nifty Gateway [11], Mintable [12], and Rarible [13]. We introduce some of them, followed by some recent attack incidents.

NFT PLATFORMS

OpenSea, self-claimed as the largest NFT marketplace, was founded in 2017. It has more than 1 million users and more than 80 million NFTs. It not only allows users to trade the NFTs, but also encourages them to mint their artworks as NFTs. Minting an NFT on OpenSea is free, and the metadata will be stored on the centralized server provided by OpenSea. However, users can also pay to store their NFTs on decentralized servers, such as Inter Planetary File System (IPFS).

LooksRare is another platform self-claimed as the community-first NFT trading marketplace. It uses its own Ethereum-based chain called LOOKS. Users who trade NFTs via LooksRare also get LOOKS tokens as rewards. LooksRare also states that the trading fees are shared by LOOKS stakeholders.

Nifty Gateway is an online NFT auction platform. Unlike other platforms, Nifty is a custodial platform, which means that the ownership of NFTs stay with the platform. As such, if a user loses their platform credentials, Nifty gateway can help with the account recovery and also revert transactions upon observing a password breach. Nifty Gateway announced the partnership with the auction house Sotheby's in 2021.

Other platforms are similar to the above. Irrespective of the platform used, the transactions recorded or completed via blockchain typically cost resources paid by the users. In addition, these trading platforms also charge fees for each transaction of the NFT, and the rate of the fees varies from 2.5 percent to 15 percent. Another difference from the transactions of traditional assets is the benefits of the creators, called cre-

ator fees. With this model, for every transaction of the NFT, the creator can get up to a preset percentage of the transaction price even if the NFT is no longer owned by the creator.

RECENT MAJOR ATTACKS ON NFTS

Along with the increase in market value, NFTs have become a popular target of attacks.

Phishing Attack on OpenSea in February 2022:

In February 2022, the dominant NFT marketplace OpenSea was attacked. OpenSea [5] updated a smart contract and required all the users to sign a transaction to make their NFTs compatible with the new contract class. The attack exploited the email OpenSea sent to the users and organized a phishing attack. Instead of providing users a link to start re-listing, the link in the phishing email directed the users to sign another transaction. Signing the transaction is identical to that the victims would like to sell their NFTs for free (0 ether). Then the attackers would send an offer saying they would like to buy the NFT at the same price (0 ether). These orders were matched and the transfer of ownership was executed. This attack resulted in a loss of $\approx$ \$1.7 million.

The Ronin Attack via NFT game Axie Infinity

in March 2022: Sky Mavis is a gaming company, and it runs an NFT-based video game called Axie Infinity [14]. The players collect and mint NFTs that represent the virtual pets called "Axies." Players can breed the pets and let them battle with each other. The game runs on an Ethereum-linked sidechain created by Sky Mavis called Ronin. Ronin runs the Proof-of-Stake (PoS) protocol for consensus using nine validators in total, and a transaction is confirmed when it can get the signature of at least five validators. During the attack, the attacker compromised the Sky Mavis's private key and controlled four validators. Then, the attacker found a backdoor through a gas-free RPC node and obtained the signature of the fifth validator. The attacker built a fake withdrawal transaction and collected signatures from five validators. After the transaction was executed, the cryptocurrency tokens were transferred to the attacker's wallet. This incident led to the loss of 173,600 ethers and \$25.5 million in total.

These frequent attacks and significant financial losses in each attack bring us to the primary question: are the NFTs as secure as the underlying blockchains that are often implied by the media hype? This question motivates us to dissect the architecture and workflow of NFTs and analyze the new attack surface they introduce.

NFT PLATFORM ARCHITECTURE AND WORKFLOW

In this section, we present the general network architecture of the existing NFT platforms, introduce the minting process that creates new NFTs, and discuss how NFTs are transacted.

NFT PLATFORM ARCHITECTURE

Most users deal with NFTs through platforms such as OpenSea and SoRare. Figure 1 shows a general platform architecture of off-chain NFTs, which usually consists of three parts, storage for metadata and assets, user applications, and blockchains (on-chain NFTs differ by using the blockchain as the storage instead). To simplify user transactions, marketplace platforms, such as OpenSea, provide user applications to interact with the under-

Given the popularity of NFTs, attackers started targeting them by compromising the underlying communication links, as well as the digital assets themselves.

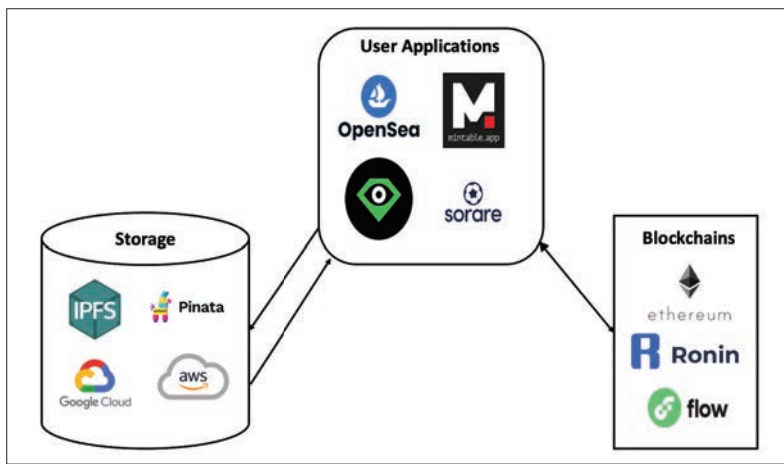


FIGURE 1. Typical Platform Architecture of Off-Chain NFT.

lying blockchain system, and a storage site for data hosting. As a result, the user can leverage the application to mint and trade NFTs while sidestepping the complex blockchain interaction. The user applications also collect data from users, such as digital assets and their attributes, which include name, description, and so on. Then the data is sent to the storage site with a link returned as the pointer. Most platforms deploy their own smart contracts for trading activities, and use smart contracts which follow a specific Ethereum token standards (e.g., ERC-721) to store the returned link on the blockchain. Thus, trades of NFTs only involve the data on the blockchains (i.e., the transactions and data within), not the data on the storage site. The storage site can store both the metadata of the NFT and the digital asset that the NFT represents, or they can be stored on different storage sites. Either a cloud server, such as Google Cloud and Amazon AWS, or a decentralized server, such as Inter Planetary File System (IPFS), can be used as the storage site.

MINTING NFTs

When a user intends to put the digital asset on the blockchain and claim its ownership, the user first needs to mint the corresponding NFT. Figure 2 shows the process of minting an NFT. Typically, minting an NFT takes three steps. First, the user, that is, the creator of the NFT, needs to decide where to put the digital asset and the corresponding metadata. Most of them are stored off-chain on third-party storage, while others are stored on blockchains. The metadata often includes some description of the digital asset and is usually in JSON format with a link (called tokenURI on the blockchain) pointing to it. Note that even though tokenURI (and even metadata) are optional under EIP-721, in practice, NFTs often include them since smart contracts rely on them to learn the name and detail of the NFT. Second, the user links the metadata to a user wallet that interfaces with the corresponding blockchain through a smart contract. The smart contract can be considered a template that takes inputs such as the recipient address (i.e., the creator address), the digital assets, and the metadata for on-chain NFTs or the tokenURI for off-chain NFTs. The smart contract would also assign tokenID to the newly minted NFT. One smart contract can be reused for multi-

ple NFTs. Finally, the user needs to use the smart contract instance, provide the inputs asked by the smart contract, and sign a transaction to mint the NFT. As a result, the tokenID (generated by smart contract) and the metadata (or the tokenURI) are stored on the blockchain in the transaction. The [ContractAddress, tokenID] tuple is the universal identifier of an NFT. Note that a smart contract may possess multiple NFTs.

To attract users, minting on platforms such as OpenSea is typically free of charge. Once an NFT is minted, its transaction is stored on the blockchain and can be traded. NFT platforms use customized smart contracts to ensure that they can charge fees for every transaction via transactions. Platforms that provide NFT minting functions usually have a higher transaction fee because they often have more NFTs available to trade. Some platforms only offer NFT trading services, thereby acting as a middleman between buyers and sellers. Such platforms typically offer a lower trading fee to incentivize traders and increasing the trading activity. This model works for media-based NFTs such as images, videos, and music. Another group of NFTs, including Cryptokitties, are game-based NFTs. They are naturally bound with the platform of the game company, which plays both roles of the NFT creator and the middleman.

TRADING NFTs

Once an NFT is minted, it can be traded. Intuitively, trading NFTs involves the transfer of the ownership of digital assets. Since an NFT involves the digital asset itself, the corresponding JSON metadata, and the transaction, we describe how they are stored before discussing how they are transferred through a transaction.

Figure 3 shows the data storage organization of the NFT. The digital assets are stored online and accessible via a public link. The link can be used to display the NFT to potential customers, but most importantly, it is used for structuring the JSON-format NFT metadata under specific standards (e.g., the EIP-721).

The JSON metadata includes multiple attributes, such as name, description, and image. If the NFT is an image, the link pointing to the image is the value of the "image" attribute in the NFT metadata. Storing and retrieving the JSON metadata also consumes time and resources. Thus, the JSON metadata is usually stored off-chain, on a centralized or decentralized server. The JSON metadata is also accessible via a public URL.

The NFT digital asset and metadata are associated via these URLs in a chained fashion: the URL of the digital asset is included in the JSON metadata. The URL of the JSON metadata is included in the transaction, that is, tokenURI, which is stored on the blockchain.

To sell an NFT, the platform of the user's choice uses the URL to the JSON format metadata and displays the digital assets to the potential customers on the front end, which is usually a web page. The owner of an NFT can list an NFT for its expected value for sale. Anyone who accepts the price and makes a payment can buy the NFT. The process is executed by the listing smart contract. On the other hand, if the owner does not list an NFT or the potential buyer cannot accept the listing price, the potential buyer can

also set up a smart contract offer with the price she/he can offer, and ask if the owner would agree on the price. The transaction can be completed if the owner accepts the price shown by a potential customer. All the transactions and smart contracts are recorded on the blockchain and are available to the public for validation.

A successful transaction will lead to the transfer of ownership of the NFT. However, such a transfer of ownership involves only updating the data stored on the blockchain, that is, new transactions, not the JSON metadata or the original digital asset. URLs are simply passed around as the parameters, and there is no protection for them. In other words, the connection between the three parts is fragile and vulnerable. If any of the URLs fails or is tampered with, the security of the NFT is compromised.

ATTACK SURFACE ANALYSIS

In this section, we aim to analyze the attack surface of NFTs, purely from the structural standpoint. Since NFTs transactions are on blockchains, we are not focusing on any known attacks on blockchains, but rather on the new attack space that NFTs have to defend against.

THREAT MODEL

By focusing on the new attack surface, we assume that the adversary aims to trick users into buying duplicated or non-existent digital assets without breaching anyone's account. The adversary may host the digital asset on a server and deploy a smart contract in the blockchain (e.g., Ethereum). The adversary then manipulates the URLs that link the tokenID to the digital asset or the link to the metadata. The URL manipulation can be characterized by different attack types presented below.

ATTACK MODELS

In principle, various attacks are possible with the understanding of the logical link between the smart contract ID and the digital asset. The attack models shown below are based on the current architecture of NFT, regardless of the trading platforms. In other words, even NFTs that are not listed on any platforms (e.g., those which are traded individually) are still vulnerable to these attack models.

Ownership Duplication: To launch this attack, the adversary can publish a new contract using an existing URL of an off-chain NFT that was used in a previous transaction. Under such a circumstance, the ownership of the NFT may be “legally” tampered with, as shown in Fig. 4a. In Transaction2, the adversary uses the metadata JM when minting the NFT, but the metadata JM has already been used in Transaction1. The ownership duplication attack can happen because there is no URL scrutiny in place during the NFT minting process.

Token Duplication: A token duplication attack is similar to an ownership duplication attack. In an ideal case, the digital asset of an off-chain NFT must be represented using a single JSON metadata file. However, in the token duplication attack, an adversary can link the digital asset to one or more JSON metadata. In principle, this allows an adversary to use the same JSON metadata file to mint an unlimited number of off-chain NFTs. The token duplication attack can happen because there is no JSON metadata scrutiny during the

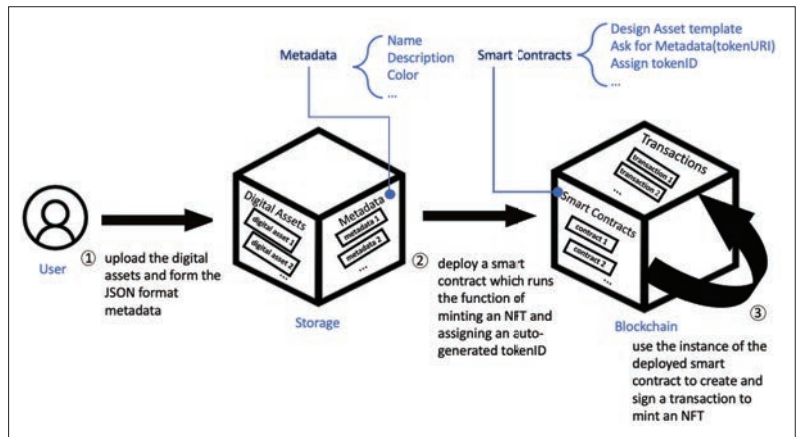


FIGURE 2. The process of minting an NFT.

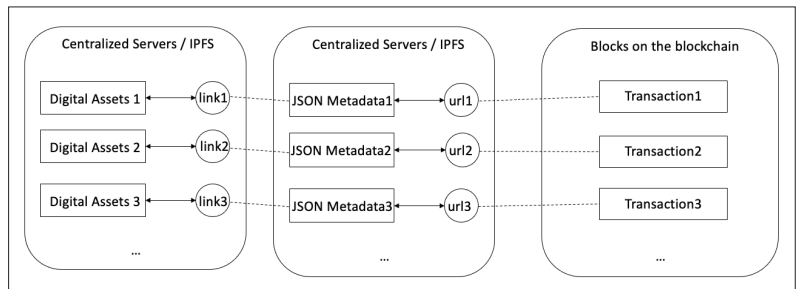


FIGURE 3. Storage organization of an off-chain NFT.

NFT minting process. Figure 4b depicts such a situation that JSON Metadata2 uses the same digital asset as JSON Metadata1 and can be minted as another NFT in Transaction.

Asset Withdrawal: In the asset withdrawal attack, an adversary can attempt to remove the digital asset from the hosting server after the off-chain NFT is sold. Figure 4c illustrates the attack. DA is the URI that links to the digital asset and is included in JSON Metadata. DA should always be available for validation. Once DA is invalid or replaced, the NFT owner will have no ownership proof of the correct digital asset. This can happen because the digital asset involved in the transaction is stored offline. Thus, if the adversary owns the digital asset, he/she can easily remove or replace the existing digital assets. The current NFT ecosystem does not provide any protection to the buyer after the transaction. This attack, however, does not work for on-chain NFTs since they are stored on blockchains.

Metadata Withdrawal: Similar to the asset withdrawal attack, in a metadata withdrawal attack, an attacker aims to make the smart contract transaction that does not link to any JSON metadata on the server, shown in Fig. 4d. Once the JM (the link to the JSON Metadata) is invalid, the NFT containing JM as tokenURI will become an “orphaned” NFT, that is, nobody knows the owner of what digital asset it represents. This is possible because the JSON metadata is also stored offline, and lacks protection. Metadata Withdrawal does not work for on-chain NFTs.

Asset Duplication: In the asset duplication attack, an attacker exploits the similarity between digital assets across different NFTs. There is no cost to put a counterfeit, extremely similar digital asset on the servers if the digital asset is stored on

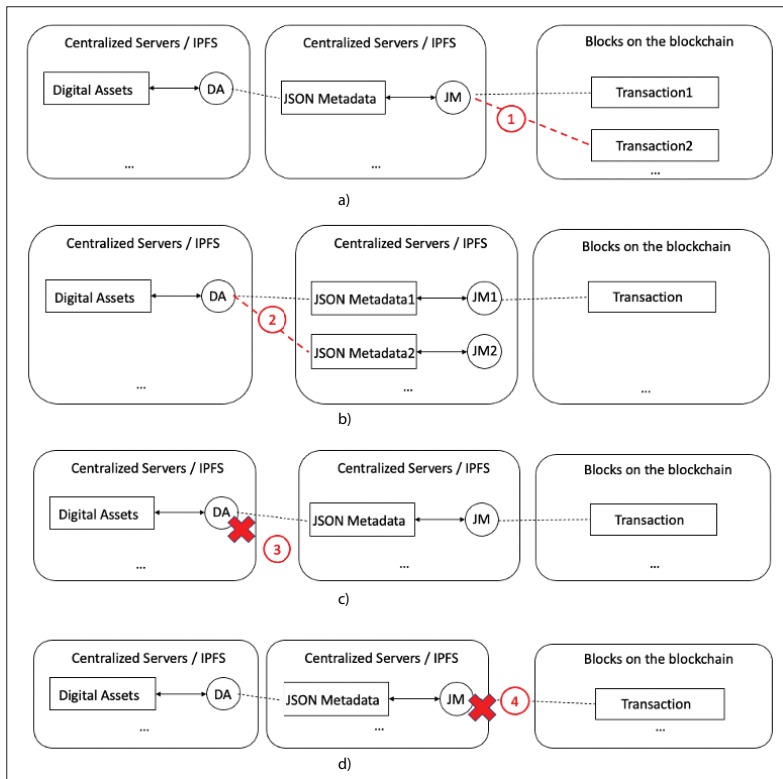


FIGURE 4. Attack Examples. Assets and metadata are rectangles, URL/links are circles: a) Ownership duplication; b) Token duplication; c) Asset withdrawal; d) Metadata withdrawal.

centralized storage servers. There is no exception even if the digital assets are stored on IPFS. Since IPFS generates links/URLs to the data based on the hash of the content of that, multiple copies of the same data are prohibited by IPFS. However, changing even a bit in the digital asset will lead to a different hash output, and the counterfeit or slightly changed digital assets are allowed to be stored on IPFS. Thus, an attacker can download an existing (and expensive) digital asset, make a minor change that is not noticeable to human eyes, and package it into another NFT for sale. Inherently, such manipulations are challenging to detect and prevent due to the nature of digital assets, whether they are stored on-chain or off-chain.

ATTACK DEMONSTRATION

To verify our analysis of potential new attacks on NFTs and confirm their feasibility while not infringing others' digital assets by any means, in this section, we experiment with mounting attacks on our own NFTs.

First, we set up two addresses on Ethereum Ropsten Testnet. The addresses were `0x34eC-f5A8C7673e6516a2cAc75599B6D58dAeb752` and `0x784B1356-7287233CF796BEED63a4-CB14fCFE935c` for *account1* and *account2*, respectively.

We used a photo, as shown in Fig. 5, taken by us as the digital property. To mint the NFT, we uploaded the photo to Google Cloud (<https://bit.ly/3f8s2K1>). We also used Pinata as the IPFS to store the metadata. Currently, Pinata is free of charge for such services.

Experiment: To mint the NFT, we created a metadata JSON file which included NFT attributes including `image_url`, `name`, and `descrip-`

`tion`. The JSON files were uploaded to the IPFS, and Pinata generated one link per JSON file, <https://bit.ly/3xCC24D> for `metadata1` and <https://bit.ly/3eXf2qn> for `metadata2`. Both metadata files linked to the same image shown in Fig. 5.

Ownership Duplication Attack: We used the smart contract shown in Listing 1 [15] and deployed it on the Ethereum test network (also called testnet). The contract address were `0x11a6685d81F44C8cc894be0aD-943446386893De2` and `0xB46a6fc74ACB-7570d44979C2AEEDeD9237e1a6Fc` for *account1* and *account2*, respectively. After we created and signed the transactions, NFTs were successfully minted and confirmed. The transaction hashes for the NFTs are `0xb4a9872d2c12d-b99a8fc73a99316796e0e36e-ada436a4a21f773815852088fb`, and `0x0c5749e5d561016ca061a3bf031cbe6f-6b763ef51c3cd4d5698d0c667ecb069b` for *account1* and *account2*, respectively. The transactions can be queried on the Ethereum testnet.

Our experiment confirmed that different accounts/address can mint the same JSON metadata as their own NFTs. That is, two accounts have the ownership of the same metadata.

Token Duplication Attack: To mount a token duplication attack, we used *account1* at the address `0x11a6685d81F44C8cc894be0aD-943446386893De2`, and the same smart contract at the address `0x11a6685d81F44C-8cc894be0aD943446386893De2`.

We uploaded a slightly different JSON file, but the attributes of the NFT, such as name, `image_url`, and description are kept the same. We then minted another NFT using a slightly modified JSON metadata. The transaction succeeded, with its transaction hash of `0x23f9642d2c1eb58b61b7500d-2cf08941b266f56be2fd23b920472ce-f927aa484`. Comparing the content of the JSON metadata files, it is obvious that the metadata files refer to the same digital property, that is, the same Walden Pond photo. However, we, the NFT creators, can mint multiple NFTs that look completely different on the blockchain. If the NFT creator sells those two NFTs to two different buyers, it will be difficult to claim ownership of one digital property.

Asset Duplication Attacks: To check if we can download an existing digital asset, modify it, and mint it as another NFT, we added a small grey-colored block (hardly visible to human eyes) on the top of the original photo and named it "modifiedWaldenPond." We then uploaded both the modifiedWaldenPond and the formed JSON metadata to Pinata. We successfully minted it as another NFT on Ethereum Ropsten Testnet. The transaction hash is `0x532f19cb29d22db-cfb1d6f1afd5cc25f977a7508a686c1a-80477e9a7d6bc94f3`.

DISCUSSION

Our initial exploration clearly shows that off-chain NFTs do not enjoy the same level of protection as the blockchain because often only the transactions are stored on the blockchain while other critical data, including the digital assets, the JSON metadata, and the connections between these dif-

ferent entities, are not stored on the blockchain. Such a decoupling, while significantly reducing the storage overhead on the blockchain, introduces new vulnerabilities to the entire NFT-based virtual economy and the metaverse in general. We next briefly discuss some improvements that will be needed in the future.

Protection of All Relevant Data: This includes not only the digital assets themselves, but also all the metadata. All such data are public, and thus, encryption is not necessary. Therefore, for digital assets, some digital copyright protection mechanisms, for example, digital watermarking, are needed to prevent them from being easily duplicated or stolen. However, digital watermarking may not be appropriate for documents or small digital assets. In such cases, other schemes, such as digital signatures, or a combination of these may be more appropriate. Similarly, all the relevant metadata should be protected as well (e.g., via message authentication code (MAC)), and thus they cannot be easily manipulated.

Protection of the Links: In NFTs, object pointers, that is, the URLs or links, are used to associate the corresponding digital assets, metadata, and contracts, and they can be easily attacked. Similar to digital assets and metadata files, the links connecting different entities should be protected in a way so that they cannot be manipulated once the NFT is minted. An intuitive approach is to include them (or their information) when signing the contract and storing them on the blockchain, forming a chained dependency.

Duplication Examination: Before the mint of any new NFTs, it is necessary to conduct a thorough examination to ensure the uniqueness of the digital assets, the metadata, the links, and so on. Intuitively, this requires a global database that can provide search and query functions. A centralized server on a cloud or a Peer-to-Peer based distributed storage, for example, based on distributed hash tables, needs to be in place for this purpose. The examination should also be done online, requiring minimal latency. In practice, building such a centralized service is challenging. A P2P approach might be more promising. For example, if an advertised NFT could be confirmed by many other verifiers or validators (e.g., a credit or a faith score) in a certain time window, the NFT could be considered more likely to be authentic, and users are more likely to buy such NFTs with such validation stamps. The verifiers/validators are held responsible (awarded or penalized) and recorded on the transaction as well. Along this line, another challenge is to have a mechanism to prevent attackers from minting very similar digital assets (e.g., only a pixel of a photo is changed). Image searching/matching techniques, for example, with machine learning assistance, may shed some light on this perspective.

While the above approach may demand more research and time, we suggest a quick rescue to include all critical information about the digital assets and the links on the blockchain. For example, in the minting process, instead of just the link information of the JSON metadata where the link is not bound to the corresponding file, a chained hash or a hash concatenation of all involved components, including the digital assets, the JSON metadata, and their corresponding URLs, could be included in the transac-



FIGURE 5. Our Digital Asset: Walden Pond Photo.

```

1 //Contract based on https://docs.openzeppelin.com
  /contracts/3.x/erc721
2
3 // SPDX-License-Identifier: MIT
4 pragma solidity ^0.7.3;
5 import "@openzeppelin/contracts/token/ERC721/
  ERC721.sol";
6 import "@openzeppelin/contracts/utils/Counters.
  sol";
7 import "@openzeppelin/contracts/access/Ownable.
  sol";
8
9 contract MyNewNFT is ERC721, Ownable {
10     using Counters for Counters.Counter;
11     Counters.Counter private _tokenIds;
12     constructor() public ERC721("MyNFT", "NFT")
13         {}
14
15     function mintMyNFT(address recipient, string
16         memory tokenURI)
17         public onlyOwner
18         returns (uint256)
19     {
20         _tokenIds.increment();
21         uint256 newTokenId = _tokenIds.current();
22         _mint(recipient, newTokenId);
23         _setTokenURI(newTokenId, tokenURI);
24         return newTokenId;
25     }
26 }

```

LISTING 1. Token Smart Contract Used [7].

tions and stored on the blockchain.

CONCLUSION

NFTs are at the core of the Metaverse virtual economy. The increasing popularity of NFTs has made them a lucrative target for attackers. In this article, we explore novel attacks on NFTs that are distinctly different from the known attacks on popular blockchain systems. Our attack surface analysis is based on the design constructs of prominent NFT implementations, and we conduct experiments to showcase the attack feasibility in the real-world. Our analysis highlights the key concerns regarding the security of NFT ecosystem, thereby emphasizing a need for more research in the domain.

REFERENCES

- [1] J. D. N. Dionisio, W. G. Burns III, and R. Gilbert, "3D Virtual Worlds and the Metaverse: Current Status and Future Possibilities," *ACM Computing Surveys*, vol. 45, no. 3, 2013, pp. 1–38.
- [2] C. Wang, C. Yu, and Y. Li, "Toward Understanding Attention

- Economy in Metaverse: A Case Study of NFT Value," *IEEE Trans. Computational Social Systems*, 2022.
- [3] S. Bouraga, "On the Popularity of Non-Fungible Tokens: Preliminary Results," *Proc. 3rd IEEE Conf. Blockchain Research Applications for Innovative Networks and Services*, 2021, pp. 49–50.
 - [4] M. Rosenfeld et al., "Overview of Colored Coins," <https://allquantor.at/blockchainbib/pdf/rosenfeld2012overview.pdf>; accessed on 02/02/2023.
 - [5] D. Piyadigama and G. Poravi, "An Analysis of the Features Considerable for NFT Recommendations," *Proc. 15th IEEE Int'l. Conf. Human System Interaction*, 2022, pp. 1–7.
 - [6] How Many NFTs Are Actually on the Blockchain? <https://www.rightclicksave.com/article/how-many-nfts-are-actually-on-the-blockchain>; accessed on 02/02/2023.
 - [7] R. Moody, "Worldwide NFT Heists Tracker," <https://www.comparitech.com/blog/vpn-privacy/nft-heists/>; accessed on 02/02/2023.
 - [8] J. Coghlan, "Akudreams Dev Team Locks Up \$33m Due to Smart Contract Bug," <https://cointelegraph.com/news/akudreams-dev-team-locks-up-34m-due-to-smart-contract-bug>; accessed on 02/02/2023.
 - [9] Q. Wang et al., "Non-Fungible Token (NFT): Overview, Evaluation, Opportunities and Challenges; arXiv preprint arXiv:2105.07447, 2021.
 - [10] LooksRare Team, "Buy & Sell NFTs, Get Rewards," <https://looksrare.org>; accessed on 02/02/2023.
 - [11] Nifty Gateway Team, Nifty gateway, <https://niftygateway.com>; accessed on 02/02/2023.
 - [12] Mintable Team, Mintable.app — home; <https://mintable.app>, accessed on 02/02/2023.
 - [13] Rarible Team, Rarible: Low Fee NFT Marketplace — buy NFTs on 5 Blockchains, <https://rarible.com>; accessed on 02/02/2023.
 - [14] P. Boonparn et al., "Social Data Analysis on Play-to-Earn Non-Fungible Tokens (NFT) Games," *Proc. 4th IEEE Global Conf. Life Sciences and Technologies*, 2022, pp. 263–64.
 - [15] S. Mudgil, "How to Write Deploy an NFT," <https://ethereum.org/en/developers/tutorials/how-to-write-and-deploy-an-nft/>; accessed on 02/02/2023.

BIOGRAPHIES

YIXIAO GAO is a Ph.D. student in Computer Science Program at George Mason University. Her research lies in the areas of blockchain and distributed systems.

MUHAMMAD SAAD is a Senior Research Scientist at PayPal, where he works on information systems security. His current research involves analyzing cryptocurrency attacks, mitigating online fraud, and developing secure authentication protocols.

ADAM OEST is a senior cybersecurity researcher at PayPal, where he leads a team focusing on the identification and mitigation of sophisticated fraud and strengthening the security of the broader web ecosystem.

JEAN ZHANG is an Associate Professor in School of Business at Virginia Commonwealth University. She works on performance measurement, governance, accounting quality, and accounting information systems.

BO HAN is an Associate Professor of Computer Science at George Mason University. His research interests are in the areas of networked systems, mobile computing, and wireless networking.

SONGQING CHEN is a Professor of Computer Science at George Mason University. His research focuses on network measurement, distributed systems, and security.